

Inferring Organisational Digital Supply Chain Dependencies from External Attack Surface Analysis

Martin Price , Edward Austin , Paul Smith , and Nicholas Race 

Lancaster University

`{m.g.price, e.austin, paul.smith, n.race}@lancaster.ac.uk`

Abstract. External Attack Surface Management (EASM) tools provide data that allows organisations to view their Internet-facing assets. Analysing this data helps an organisation take steps to mitigate possible cyber attacks. Existing research often uses this data to highlight vulnerable systems and services, such as those using insecure software. Our work goes beyond this to propose a novel use of EASM tools that yields insights into an organisation’s digital supply chain. This lens highlights which digital services could be used for a supply chain attack, helping analysts understand where to take preemptive action. We explore the value of our approach through three real-world use cases: the English government, a ‘Motor Vehicle and Parts’ corporation, and a ‘Trucking, Transport, and Logistics’ corporation. Our findings highlight systemic dependencies on specific Cloud providers and software that is widely used across an organisation. Furthermore, we were able to identify a financial digital service supporting an organisation’s business. All these findings highlight where an impactful digital supply chain attack can take place, providing a novel view of the threat.

Keywords: External Attack Surface · Measurement · Digital Services · Organisation · Digital Supply Chain

1 Introduction

Cyber attacks against organisations are an ever-present threat. In 2025, the UK government found that around 43% of businesses within the UK suffered a cyber attack or data breach, with medium and large organisations facing most of them [20]. This increasing threat has led security teams to employ a range of tools and techniques, including External Attack Surface Management (EASM) tools, to identify the attack surface of their digital estate – the Internet-facing assets that an adversary could target [21].

Seed data is the initial information, such as domain names, provided to EASM tools to discover an attack surface. Recent research has investigated ways to apply these new tools [9,13]. These works often focus on determining the number of IP addresses present or identifying the Common Vulnerabilities and Exposures

(CVE) [1] entries that are associated with the software exposed at an IP address. Whilst these are useful as an initial indicator of which systems and services require attention, they do not provide information about digital supply chain dependencies. Insights regarding digital supply chains are becoming increasingly important as adversaries use them as a means to attack targets. For example, the NotPetya 2017 attack, which compromised software in the supply chain, caused 76 global port terminals to close [15].

EASM tools can provide more than IP addresses and CVE entries, including domains, subdomains, IP operators, and details of running software. We propose to use this data, along with data that is collected using Open-Source Intelligence (OSINT) gathering techniques, to characterise the Internet-visible digital supply chain of an organisation. For example, we can identify frequently used Cloud providers and software that is used across an organisation’s digital supply chain. The benefit of identifying exposed parts of the supply chain is that it highlights digital service dependencies that could be used for an indirect attack, permitting organisations to take preemptive measures. However, there is a challenge in understanding the relationship between specific aspects of an attack surface – and therefore aspects of a digital supply chain, and an organisation. For example, does the wider organisation use a specific software, or is it used by a single subsidiary? In other words, how dependent is an organisation on this digital service? Measuring this relationship will help organisations understand the reliance on a specific dependency and highlight where an adversary could cause widespread damage.

In this paper, we propose a novel approach to extend EASM tool-based analysis by applying previously under-utilised data, such as subdomains and IP operators, to discover aspects of the digital supply chain. Examining this data using Jaccard scores and graph-based analysis allows us to measure an organisation’s dependency on individual providers within the digital supply chain. Although the digital supply chain contains different types of providers, we focus on those that provide a *digital service* or *software*. A benefit of our approach, which maps the attack surface of an organisation, is that it provides an external adversary’s perspective – one they will use to orchestrate an attack. As Kampourakis et al. [15] observe, adversaries are now targeting digital supply chains to disrupt their targets, and so our work is a timely development as it allows analysts to understand how they might be targeted. We indicate the utility of our approach through three real-world use cases: The English government, a ‘Motor Vehicle and Parts’ corporation, and a ‘Transportation, Trucks, and Logistics’ corporation. We found multiple digital services that are visible to an adversary, highlighting how these use cases could suffer from a supply chain attack, and providing the information necessary to reduce the risk.

2 Background

In this section, we discuss the key concepts that underpin our contributions. We start by providing a brief overview of how EASM is conducted and what tools can

be used to achieve this. Additionally, we detail our definition of an organisation. This clarifies the exact scope of our attack surfaces and details the relationship between digital service providers and entities within the organisation.

2.1 EASM Overview

In general, EASM has the following workflow [14]: first, the scope of the attack surface is defined. This consists of detailing the seed data that will be used within EASM tools, such as IP addresses, network ranges, and domain names. This data is further expanded via asset discovery with techniques like subdomain enumeration. Finally, seed data is converted into an inventory of IP addresses through methods such as DNS lookups. This inventory is referred to as the ‘attack surface’ of an organisation, with the prefix ‘external’ if all of these addresses are Internet-facing. This surface can then be scanned to discover useful data, such as the software running on an IP address. This data is used for analysis.

The EASM workflow presented in this work differs from the above in two key areas. First, we introduce a novel definition of an organisation, implemented as a new step when scoping the attack surface. This change requires an adjustment to how seed data is gathered and matched, including an exploratory use of LLMs to supplement this task. Crucially, this definition allows for the second key area that explores novel approaches to attack surface analysis, in which we employ mathematical and graph-based approaches to infer aspects of the organisation’s digital supply chain.

From the perspective of EASM tooling, there are several self-hosted options available, such as OWASP Amass [8]. Recently, there has been a trend to use online-based Internet Intelligence Providers (IIPs), such as Shodan [3] and Censys [7]. These are attractive options, by employing EASM methods at-scale across the entire IPv4 Internet, and allowing access to the resulting data through APIs. In summary, they provide users instant access to actionable information. Crucially, they take responsibility for the technical, ethical, or possibly legal issues that arise when using self-hosted tools. Also, they deploy a magnitude of probes from vantage points around the globe. Because of these benefits, academia [12,6,16] has begun to use IIPs as sources of information. However, as with self-hosted methods, users still require seed data to know where to begin the search for their digital estate.

2.2 Defining an Organisation

Existing EASM research does not make clear how organisations are defined. We argue that this is a shortcoming, as different interpretations have an impact on both the mapping of the attack surface and how findings are communicated. As such, the first stage of our method is to define what is, and is not, classified within an organisation’s digital estate. We use a definition from organisational theory [4] and law [17]. In these fields, there exists the concept of an ‘Organisational Group’. Such groups are sets of legally distinct entities that operate under a parent organisation, and are often financially tied to one another. This

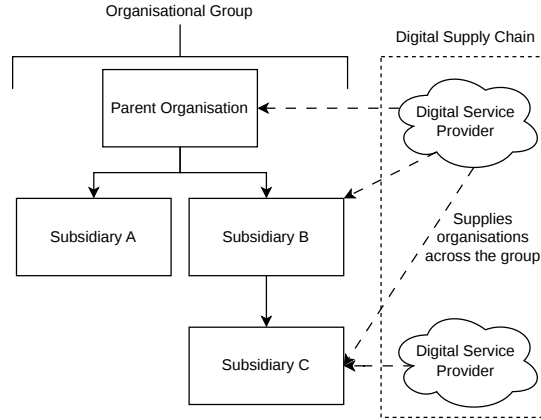


Fig. 1: An example organisational group, detailing hierarchy and the digital supply chain. Our goal is to identify the digital service providers that support the organisation and its subsidiaries.

definition usefully covers hierarchical entities such as corporate groups, consisting of multiple private companies, and nation-states, in which there are multiple levels of authority. Figure 1 highlights the structure of organisational groups and emphasises the issue from a cyber security perspective, where different entities within the group share service providers within their digital supply chains. For simplicity, we refer to organisational groups as ‘organisations’, which are made up of ‘entities’, which can refer to the parent company, subsidiaries, etc. Defining organisations this way has two key benefits: first, we have a clear definition that captures the hierarchy of modern organisations, allowing us to examine the relationship between the digital supply chain and organisational structure. Second, the same methodology can be applied to a variety of use cases, such as corporate groups and nation-states.

3 Related Work

3.1 EASM Research

Gelertner et al. [9] investigate the external attack surfaces of organisations. However, they fail to define an organisation. This is a crucial issue, as varying definitions will interpret the results differently. An example of this problem is Volkswagen AG, a Fortune 500 company referenced in their paper. This corporate group consists of multiple car manufacturers, including Volkswagen, Audi, and Bentley. Their work leaves it unclear if the digital estates of these manufacturers would be included with Volkswagen AG. Our work defines an organisation as the sum of itself and its subsidiaries, capturing the nuance of the Volkswagen AG example. This novel approach introduces clarity on how an organisation is

represented through its attack surface. This approach introduces new challenges in understanding the structure of an organisation and the relationship with the attack surface.

Recently, there has been a growing interest in national-scale EASM. Harry et al. [12] released a study on the external attack surface of American counties. However, it is primarily focused on identifying CVEs and only captures one level of government. There exists no research that captures the bigger picture of a multi-level national attack surface. As a result, our contribution provides a further novelty in that it examines the external attack surface for multiple levels within the English government. This highlights how our work is useful to governmental analysts.

3.2 Understanding the Digital Supply Chain

Attacks through the digital supply chain are not a new phenomenon. Research has found that adversaries are exploiting trusted service providers to attack targets [15]. Indeed, there are famous examples of this happening, such as NotPetya, against a corporation in 2017 [15], and SolarWinds against the United States government in 2020 [2]. Both of these attacks were executed by compromising a trusted software that was widely used by the targets. With this increasing threat, research has aimed to mitigate the supply chain risk [23,5], yet there is no work aimed at identifying an organisation’s supply chain from an adversarial perspective. Our work achieves this by leveraging EASM tools to create a similar view to what an adversary might expect through open-source data. As such, it can identify the organisation-wide services that could be targeted in a NotPetya or SolarWinds-style attack.

This paper expands on existing work in two key areas: first, an organisation is defined by using existing concepts from other disciplines. These points address the concerns from existing research and help the reader understand the resulting attack surface. Second, this paper uses EASM tool data to uncover Internet-visible aspects of an organisation’s digital supply chain, an ability missing from existing research.

4 Extended EASM Pipeline

In this section, we present our novel approach to conducting EASM by creating an attack surface for an organisation, which is then combined with novel analysis techniques to infer aspects of the digital supply chain. Initially, we discuss how an organisation is mapped with respect to its hierarchy. Then, the domains used by the organisation are identified and used in existing EASM approaches to create a list of IP addresses used by each organisation. Additionally, LLMs are explored as an option to supplement these steps. Finally, these IP addresses are novelly analysed using techniques like Jaccard scores and graph-based approaches to determine how dependent the organisation is on given digital services. This entire process is outlined in Fig. 2, along with a fictitious example for an organisation

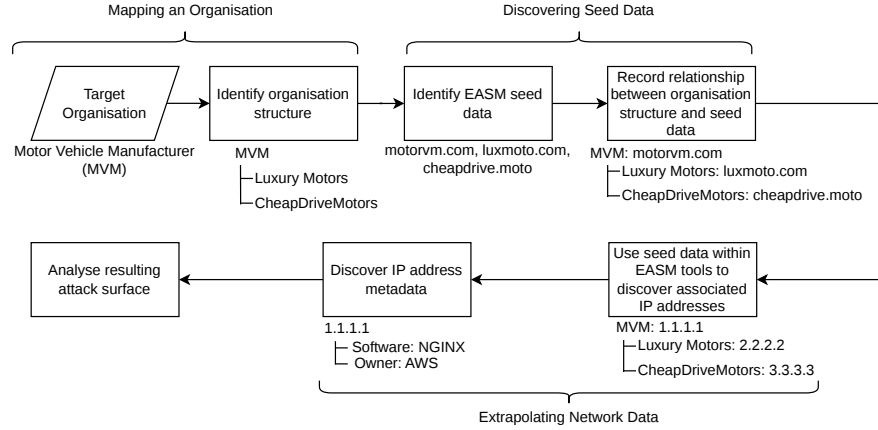


Fig. 2: Generalised overview of our EASM pipeline. A fictitious example accompanies each step to help the reader understand the process.

called Motor Vehicle Manufacturer (MVM), to help the reader understand the inputs and outputs of each stage. Sections 4.1 through 4.3 correspond to the major activities that are shown in Fig. 2; the remaining subsections discuss some of the details of our approach.

4.1 Mapping an Organisation

Careful mapping of the organisational structure is a crucial first stage of our pipeline. The results will affect what is used as seed data and, thus, the mapping of the attack surface. By leveraging Open-Source Intelligence (OSINT), it is possible to gain insight into the organisational structure, such as using corporate webpages detailing subsidiaries. Crucially, the use of OSINT mimics what an adversary might do, as they lack access to insider information about the target. As part of our workflow, we also propose utilising an LLM to automate this information-gathering process. This process is discussed in use-case-specific detail in Section 5.

4.2 Discovering Seed Data

Seed data is the initial bundle of information used within EASM tools. In our context, seed data represents the domains and subdomains used by an organisation. However, there is no authoritative source detailing which organisation uses which network assets. For example, a Regional Internet Registry may reveal the IP blocks assigned to an organisation, but will not reveal any cloud services used by said organisation. OSINT plays a role here, such as finding official domains through scraping known websites. Again, LLMs are useful to automate this role, and their feasibility is discussed later in this paper; however, human confirmation is required to ensure the LLM outputs are accurate.

4.3 Extrapolating Network Data

Following existing EASM approaches, it is possible to convert our seed data into actionable IP address information. This process, set out by [12], involves first using Censys [7] to convert the domains and enumerated subdomains into a list of IP addresses. These addresses represent the scope of the external attack surface. Each IP address is then queried in Shodan [3] to discover any metadata associated with it, such as exposed services, software, and registered owner, all of which could represent aspects within the digital supply chain. Importantly, the output of this process has a novel association with the organisation that uses each IP address, as seen in Figure 2. As such, we have a direct association between organisations and parts of their digital supply chain.

4.4 Exploratory Use of LLMs

As mentioned, off-the-shelf LLMs can be used to automate the discovery of organisational and network seed data. They are well-suited to this task because they can perform Named Entity Recognition (NER) on OSINT data [22], and make the semantic links between the discovered entities. This work utilises ChatGPT-5 mini, with web search enabled. Web search is crucial as it supplements the training data, allowing it to run NER on sources relevant to the target organisation. To keep the responses concise, the LLM is initially instructed to return a CSV-formatted file with the format represented in Table 1. This table provides an example response from the LLM. The prompt also encourages the LLM to return multiple domains for organisations, if applicable, by separating them with ‘|’. After preloading the LLM with the structure, the following prompt is given: *Task: Using data from the Internet, export a CSV-formatted file containing all organisations within the corporate group {Corporate Group Name}*. Alongside this, the LLM is told to reflect the corporate hierarchy, via the parent column, and include any regional subsidiaries, legal entities, acquired brands, and joint ventures. The LLM’s response is then normalised by cleaning the data, removing any repeated organisations, and fixing any issues within the columns. During this process, human oversight ensures that the organisations are truly part of the corporate group. The result is a verified subset of organisations that belong to a corporate group.

Table 1: Example response from the LLM when prompted for a corporate group. Note, multiple domains within an organisation are separated by ‘|’

Organisation	Parent	Domains	About
ACME Holdings	N/A	acme-hold.com	Fake Parent
ACME	ACME Holdings	acme.com ac.me	Fake Subsidiary

4.5 New Approach to EASM Analysis

With data gathered through the above means, it is possible to discover digital service providers within the overall digital supply chain. This section focuses on three types of analysis: identifying popular third-party hosting providers, including cloud providers; identifying key digital services beyond hosting, such as software; and understanding the supply chain overlap between related organisations. The first two types of analysis directly relate to discovering the digital services of the organisation, the key research question in this paper. The final approach measures how widespread a service is within the organisation. For consistency, these sub-section headers are repeated in the results.

Third-Party Hosting. There are multiple ways to discover key third-party hosting companies, but they all rely on identifying the owner of an IP address. This is possible manually, through tools such as WHOIS, or with the data provided by IIPs. These approaches will detail who officially owns an IP address according to the Regional Internet Registry. This is different than identifying who is using the domain as done when extrapolating network data. For example, an IP address may be owned by a hosting company, but is used by a customer. It is also possible to identify the cloud IP address and cloud-specific data, such as the region the address resides in. This is possible through OSINT as cloud companies publish a list of their IP addresses per region. Again, IIPs incorporate this cloud data and automate the tagging process.

Digital Services. There are many digital services outside of hosting. These can be clearly measurable products, such as identifiable software, or more complex solutions, like operating a third-party payment system. Discovering what software is used requires scans against each IP address. IIPs provide this data, having done Internet-wide scanning themselves. Discovering more complex products requires manual investigation, as there is no distinct label or tool to identify them. For example, an organisation might use a service that sits on an identifiable subdomain in their network; in this scenario, it is possible to identify the vendor through the subdomain. To semi-automate the process, the full domain can be split into its constituent parts and sorted by popularity across the entire dataset. Take the following subdomain: *service.organisation-domain.com*; this has a clearly identifiable service, and is a subdomain of the target organisation. As such, it is sensible to assume that the target organisation uses this service. Of course, without confirmation from the organisation, it cannot be 100% certain.

Organisational Similarity. This concept aims to understand how a digital service is deployed within an organisation – Is it used by a single subsidiary, or is it more widespread? To measure this, we take two approaches. First, how the organisation’s digital footprint spreads across cloud providers. This expands further on the previous third-Party hosting approach by leveraging graph-based analysis. This directly compares the relationship of different entities within the

organisation and the cloud providers. A second method to compare similarity is by using a Jaccard Score, which calculates the overlap between two sets of data. In this case, the sets consist of the software used by each organisation within a group. This provides a method to understand how software is reused across the organisation. The formula for a Jaccard Score is:

$$J(A, B) = \frac{|A \cap B|}{|A \cup B|}$$

5 Use Cases

To emphasise the usefulness of our approach, we map attack surfaces across multiple organisations. These include a surface for multiple tiers of the English Government, and anonymised international corporate groups from two sectors, listed in the Fortune 500: Transportation, Trucks, and Logistics; and Motor Vehicles and Parts. For consistency, nation-states and corporate groups will be separated within the results.

5.1 Corporate Groups

Mapping corporate groups without access to internal knowledge can be difficult due to a lack of unified sources detailing organisations and their domains. This seed data is, instead, scattered across the Internet through multiple public sources, such as investor reports. As such, a method is needed to find, parse, and aggregate data through OSINT. LLMs can be used here, being able to draw a view of a corporate group’s hierarchy and domain list from a variety of sources. These domains are then used to query Censys to find all the IP addresses hosting them or any subdomain. These IP addresses are then queried in Shodan to aggregate data such as the IP address operator and identifiable software. This approach of using Censys to find IPs and Shodan for actionable data is a method used by previous research [12], though the seed data and how the results are analysed differ completely. This process is repeated for two different corporate groups to prove the validity of the methodology and highlight how findings change across sectors.

5.2 Nation-State

For the nation-state use case, England was considered for two main reasons: first, there is an annually-released list of every official .gov.uk domain [11]; this serves as the network seed data, which can create an attack surface that spans across all levels of government. Secondly, the Office for National Statistics (ONS) publish datasets containing every distinct governmental entity within the country, and how they relate to each other. This allows an analysis across different levels of Government. LLMs were not used due to the easy access to both seed data and organisational structure data. Despite this availability, there is no officially

published link between the domains and the authority they belong to. It is important to note that Local government follows a hierarchy: Local Authority Districts (LADs) are the highest tier of local government in our dataset, and represent large geographical areas or regions of high density, such as cities. The tier below this represents Parishes. These are smaller, often rural areas, and multiple parishes can exist within one LAD; they do not cross multiple LADs. In the results, all IP addresses attributed to a Parish are not attributed to the parent LAD, as they are separate authoritative entities.

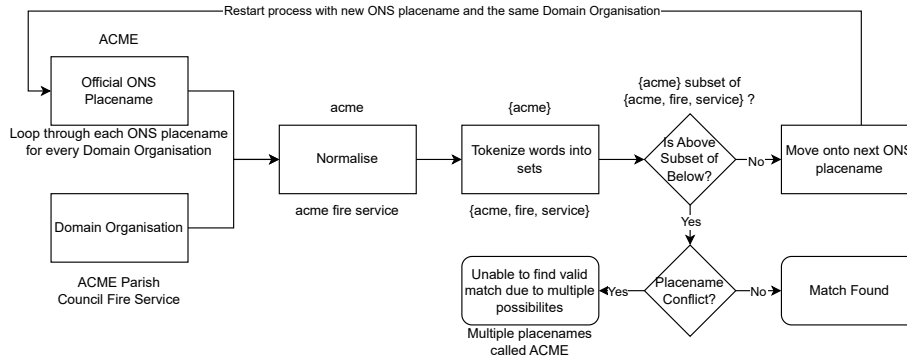


Fig. 3: Walkthrough of the string comparison process during the Nation-State seed data gathering stage. Used to match the listed authorities of domain names with official ONS placenames.

To help the reader understand this issue, the following example is used both in this text and in Fig. 3: $\{ACME\}$ *Parish Council Fire Service*, with $\{ACME\}$ being the ONS placename. The problem is the need to identify the government entity within the text, i.e., *ACME*. To do this, first, both strings are normalised by converting them to lowercase and removing common words, such as “Paris” and “Council”. After that, Named Entity Recognition is used to identify the different entities within the text. Finally, there is a check to see if all of the ONS placename entities are present within the Domain Organisation, i.e. *is {acme} in {acme fire service}*? If they are, we have at least one match and the process is then repeated for all ONS placenames. Multiple matches indicate a conflict, and the domain is tagged in the database and removed from the results. Identifying Central Government entities is much easier, as they all follow a similar trend of keywords, such as “Ministry”, “Department”, and “Office”. As such, we tag a domain as ‘Central Government’ if the domain organisation contains one of these keywords. The results of this process are detailed in Table 2

Table 2: Breakdown of English Government organisation matching and IP addresses per the matching result.

Organisation State	Total Entities	Distinct IPs
Total Orgs	3176	8784
Matched	2490	6116
Parish	1543	2540
LAD	282	4153
Central	130	1783
Conflict	658	976
Unmatched	561	2586

Cloud Providers for Motor Vehicles and Parts Organisation

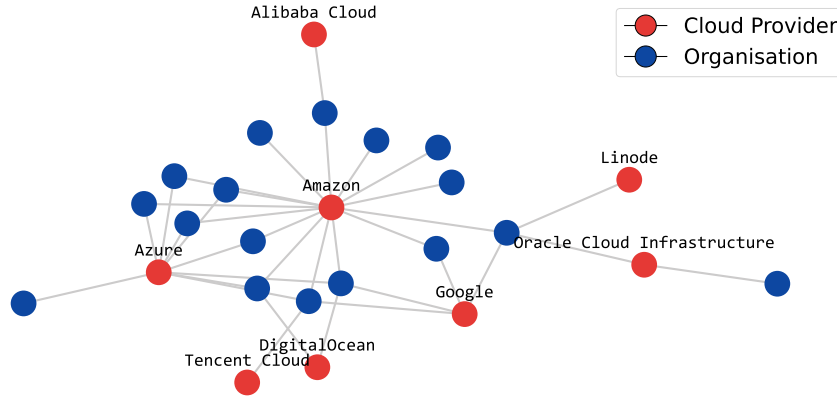


Fig. 4: Graph showing the relationship between cloud providers (red) and entities (blue) within the Motor Vehicle and Parts Organisation.

6 Results

In this section, we discuss the key findings uncovered through our attack surface generation and analysis. It is divided into two subsections that individually focus on the Corporate Group use cases and the Nation-State. These subsections follow the structural layout used in Section 3.3.

6.1 Corporate Group

This section discusses the key findings for the corporate group usecases. These corporations have been anonymised. As such, they are referred to as the Motor Vehicle and Parts Organisation (MVPO) and the Transportation, Trucking, and Logistics Organisation (TTLO).

Third-Party Hosting. Understanding the key cloud providers used by an organisation can indicate who an adversary might target to leak data. Figure 4

details the externally-visible cloud systems used by entities within the MVPO, with the clouds represented by red nodes and entities with blue. Through this analysis, it is possible to infer two main cloud providers that are used across the organisation: Amazon and Azure. Though this does not reveal what these are used for, it does highlight a visible cross-organisational dependence, one that invites further investigation. These two providers act as a force multiplier, where an attacker can disrupt multiple parts of the organisation. Also of interest are the instances where a cloud is used by a single entity. For example, the use of Tencent and Alibaba; these are both popular providers for the Asian market and likely support the company’s business there. These outliers may be appealing to adversaries looking to cause region-wide damage. Furthermore, knowing these prevalent providers can help adversaries tailor specific phishing attempts where they impersonate one of these providers. However, it is important to note that though you know these providers are used, this graph does not reveal the true reliance on them or the exact services in use. Instead, it serves as an initial step in an adversary’s reconnaissance ability, narrowing down their possible avenues of attack.

Digital Services. As mentioned in the methodology, it is possible to find digital services through analysis of the domain and subdomain names. By splitting each domain into its constituent parts, i.e., the subdomain(s), domain, and Top-Level Domain (TLD), and ranking them in occurrence, it is possible to identify indicators of vendors. Figure 5 demonstrates this for the TTLO. This graph was generated through the aforementioned method, and any possible identifiers have been anonymised, including the country code TLD (ccTLD). In Fig. 5, the second and third domain segments are commonly used by a company that provides services for business finances. Following a manual investigation, this business is not part of the corporate group under investigation and may be integrated into their client-facing financial system. This vendor is an attractive target for a would-be adversary, and an attack could have financial ramifications for the corporate group that relies on it.

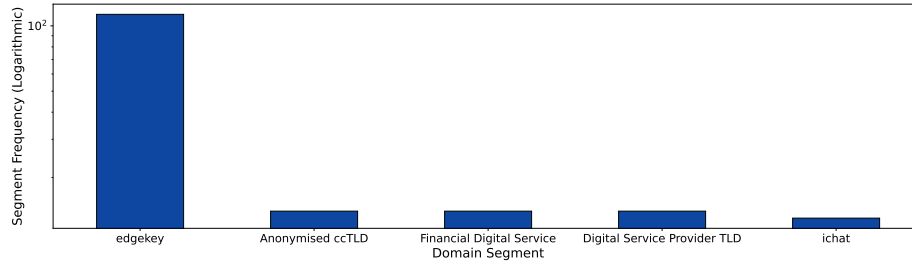


Fig. 5: The top 5 domain segments for Transportation, Trucking, and Logistics. These segments show a financial digital service provider that deploys its product through an identifiable subdomain.

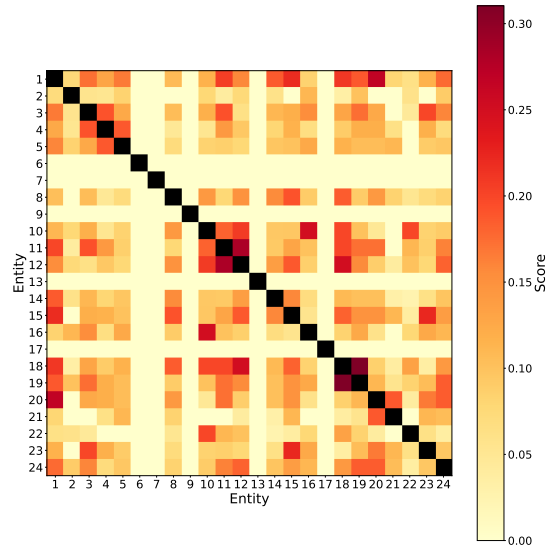


Fig. 6: Heatmap detailing the Jaccard Scores for sets of software used by entities within the Motor Vehicle and Parts Organisation.

Organisational Similarity. Figure 6 represents Jaccard scores between sets of software used by entities within the MVPO. The darker the square, the greater the overlap between the entities. This software, as detected by Shodan, can be vulnerable to the given CVEs, and an overlap represents an opportunity where an adversary can reuse an attack across multiple targets. Immediately from the heatmap, there are clear clusters where entities within the organisation reuse the same software. The most overlap occurs with entities 18 and 19, both of which represent passenger car brands within the MVPO. This highlights an instance where similar subsidiaries have an overlapping supply chain. As such, it may be possible for an adversary to use the same attack against both entities, using one as a live testing ground for the other. This could allow the attacker to practice their execution, minimising the time between initial access and extraction.

6.2 Nation-State

This section details the results for the English government. It starts with the key third-party hosting providers, followed by the most popular software used by authorities of all tiers, and finally, the reliance on cloud providers and how that differs between the tiers.

It is important to note that when discussing the tiers of Government here, the results only include those that could be matched with ONS data. As such, it is not the complete ground-truth of the entire English Government, but rather an identifiable lens.

Table 3: Number of instances where hosting providers supply neighbouring Local Authority Districts, divided into regions.

Region	Neighbouring Providers	Not ‘Big Three’
West Midlands	93	36
South East	193	97
East of England	150	68
North West	54	20
Yorkshire and The Humber	60	27
South West	115	66
London	42	15
East Midlands	92	31
North East	28	13

Third-Party Hosting. By identifying hosting providers, it is possible to infer which third parties could be targeted for maximum impact. With nation-states, there is an added nuance; local authorities are tied to a geographical location, and neighbouring authorities may rely on the same hosting provider. Table 3 highlights this phenomenon. It counts all of the instances where neighbouring LADs share the same provider, and includes situations where they share multiple of them. Furthermore, the right column counts how many of those instances do not include one of the ‘Big Three’ cloud providers: Amazon, Google, or Microsoft. This geographic reliance on specific providers introduces a unique attack vector. If an adversary wants to target a specific geographical area, they can use this data to execute an attack against certain hosting providers that affect the relevant LADs. Conversely, if the adversary’s goal is widespread, indiscriminate damage, they can use this data to find providers who supply the most LADs. These scenarios have no clear remediation. The last column in Table 3 highlights the geographical reliance on these non-‘Big Three’ providers, which might invite more scrutiny from adversaries trying to find a weak link in the supply chain.

Digital Services. Figure 7 details the five most popular software, represented as Common Platform Enumerations (CPEs), across the combined English attack surface, and further splits each column into the constituent tiers, highlighting how each contributes to its popularity. It is important to note that CPEs that refer to a CDN, such as Cloudflare, have been removed, to only focus on the detectable software in use, as Cloudflare masks this. Also, Parishes and LADs contribute the most to the majority of CPEs, which makes sense as there are many more of these entities than there are those in central government. As one could expect, the most popular software is some form of website hosting product, such as NGINX [19] and Apache HTTP Server [24]. Of note is EXIM, which is a message transfer agent that has been targeted during crypto-jacking campaigns [18]. Though Fig. 7 does not detail the exact version numbers, an adversary may be intrigued by the use of EXIM and probe further to determine if existing exploits are usable. This invites a unique possibility to set up a honeypot,

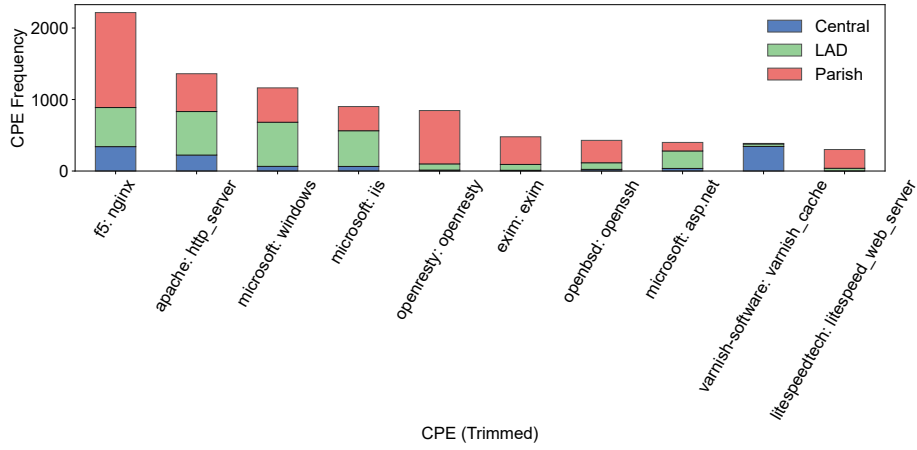


Fig. 7: The top 5 most popular CPEs across all English authorities, divided into tiers of Government.

advertising as a vulnerable EXIM instance, to monitor adversaries. The lack of any software being notably used by the Central Government is most likely due to the aforementioned cutting of CDN-related CPEs. Indeed, out of the 1782 IP addresses attributed to the Central Government, 64% of them are attributed to one of Amazon, Akamai, Cloudflare, or Fastly, all of whom provide CDN services. For this reason, there are fewer true software CPEs to analyse.

Organisational Similarity. Of key interest is the relationship between English authorities and cloud providers, and how they differ between the different tiers of authority. Figure 8 provides a clear view of these relationships. This network graph traces the relationship between Shodan-defined cloud providers and each tier of authority. This only maps authorities that use these providers; Parishes are in blue, LADs in green, and Central Government in orange. It shows the Central Government tends to prefer Amazon and Azure, and Google, with the majority often relying on multiple cloud providers. Similarly, LADs make use of Amazon and Azure, but there are more that rely on a single provider, when compared to the Central Government. Parishes, conversely, make use of a broader spectrum of cloud providers, and usually only use one, with the favourite being Google. This shows a clear distinction in the digital footprint between the tiers of Government. Crucially, the instances where authorities rely on a single provider introduce the possibility of a single-point-of-failure, wherein a cloud provider outage – as the one AWS suffered in October 2025 [10] – can disrupt a large number of authorities. Of course, this data does not tell us how these clouds are used; as such, the importance in the organisation’s operation is unknown, and, therefore, so is the severity of disruption.

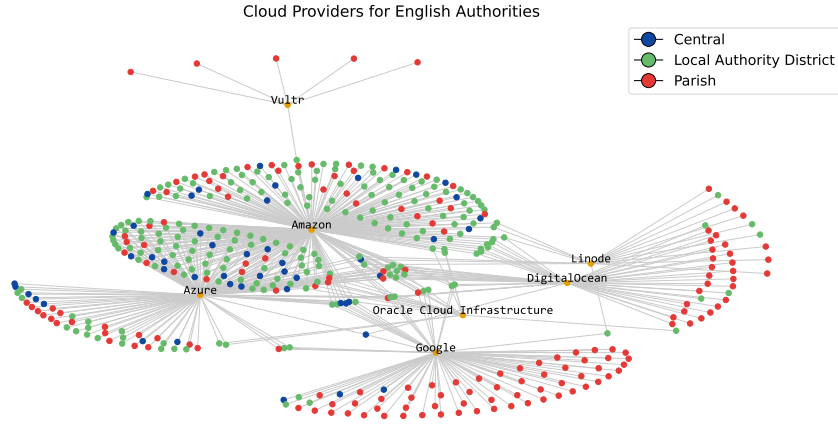


Fig. 8: A Graph showing the relationship between English Authorities and Cloud Providers. This does not include authorities that do not use any provider.

7 Limitations

A key issue with IIPs, highlighted by this work, is the inability to detect accurate results for websites behind CDNs. For example, Cloudflare may be identified as the software used by an IP address despite merely masking the organisation’s underlying infrastructure. Fig. 7 highlights this as Varnish Cache, a CDN, masks the software used by the target organisation.

Techniques, such as NAT, subnetting, and multi-tenancy hosting, impact the data. Because EASM tools scan IP addresses, they may aggregate results from multiple tenants sharing the same address. Therefore, software used by one tenant may be incorrectly attributed to others. This can result in false-positives being reported in the data, affecting the integrity of the results.

This paper has found instances where entities within an organisation share digital providers. However, the work does not shed light on how integral these shared suppliers are for the overall day-to-day operations of the organisation. It remains unclear whether these suppliers are peripheral or operationally critical.

This work made use of LLMs to uncover seed data, as described in Section 5.1. Notoriously, these LLMs are prone to intrinsic issues such as hallucinations, which can affect the quality of the derived seed data. To counter this, we manually checked all of the data to ensure that the responses are factual. Though this was suitable for the use cases presented here, it would be difficult to scale the methodology across a dataset containing many organisations.

8 Conclusion

This work has looked at how to yield insights about an organisation’s digital supply chain through the external attack surface. With novel approaches to EASM

analysis, we infer multiple digital services within the digital supply chain. We validated our approach with three real-world use cases: the English Government, a Motor Vehicle and Parts corporation, and a Transportation, Trucking and Logistics corporation. These approaches, which leverage Jaccard Scores and graph-based analysis, found the popular Cloud providers used within the organisation, the popular software used – including how different parts of the organisation share specific software, and an instance of an identifiable third-party financial system. Crucially, because this work is built upon open-source data, these findings represent a view that an adversary can recreate. As such, it highlights the avenues where a digital supply chain attack can be visualised and attempted. Also, this work provides the basis for future work investigating broader supply chain analysis, such as using EASM data to discover popular hardware providers within an organisation. Our work provides security analysts with information on how they could be attacked, allowing them to take preemptive measures to secure against supply chain attacks and reduce the risk faced.

Disclosure of Interests. The authors have no competing interests to declare that are relevant to the content of this article.

References

1. CVE: Common Vulnerabilities and Exposures, <https://www.cve.org/>
2. SolarWinds | National Cyber Security Centre (2021), <https://www.ncsc.gov.uk/collection/ncsc-annual-review-2021/the-threat/solarwinds>
3. Shodan. Shodan (2026), <https://www.shodan.io>
4. Ahrne, G., Brunsson, N.: Organizations and meta-organizations. *Scandinavian Journal of Management* **21**(4), 429–449 (Dec 2005). <https://doi.org/10.1016/j.scaman.2005.09.005>
5. Andreoli, A., Lounis, A., Debbabi, M., Hanna, A.: On the prevalence of software supply chain attacks: Empirical study and investigative framework. *Forensic Science International: Digital Investigation* **44**, 301508 (Mar 2023). <https://doi.org/10.1016/j.fsidi.2023.301508>
6. Ashley, T., Gourisetti, S.N.G., Brown, N., Bonebrake, C.: Aggregate attack surface management for network discovery of operational technology. *Computers & Security* **123**, 102939 (Dec 2022). <https://doi.org/10.1016/j.cose.2022.102939>
7. Durumeric, Z., Adrian, D., Mirian, A., Bailey, M., Halderman, J.A.: A search engine backed by internet-wide scanning. *CCS '15* (Oct 2015). <https://doi.org/10.1145/2810103.2813703>
8. Foley, J.: OWASP Amass, <https://owasp.org/www-project-amass/>
9. Gelernter, N., Schulmann, H., Waidner, M.: External attack-surface of modern organizations. pp. 589–604. *ASIA CCS '24* (Jul 2024). <https://doi.org/10.1145/3634737.3656295>
10. Goodin, D.: A single point of failure triggered the Amazon outage affecting millions (Oct 2025), <https://arstechnica.com/gadgets/2025/10/a-single-point-of-failure-triggered-the-amazon-outage-affecting-millions/>
11. Government Digital Service, Central Digital and Data Office: List of .gov.uk domain names (2026), <https://www.gov.uk/government/publications/list-of-gov-uk-domain-names>, accessed: 2026-05-19

12. Harry, C., Sivan-Sevilla, I., McDermott, M.: Measuring the size and severity of the integrated cyber attack surface across US county governments. *Journal of Cybersecurity* **11**(1), tyae032 (Jan 2025). <https://doi.org/10.1093/cybsec/tyae032>
13. Hossain, S.T., Yigitcanlar, T., Nguyen, K., Xu, Y.: Cybersecurity in local governments: A systematic review and framework of key challenges. *Urban Governance* **5**(1), 1–19 (Mar 2025). <https://doi.org/10.1016/j.ugj.2024.12.010>
14. Husák, M., Sadlek, L.: Attack Surface Management: State of the Art and Operational Challenges. In: 2025 IEEE 11th International Conference on Network Softwarization (NetSoft). pp. 1–6 (Jun 2025). <https://doi.org/10.1109/NetSoft64993.2025.11080588>
15. Kampourakis, V., Kavallieratos, G., Gkioulos, V., Katsikas, S.: Cracks in the chain: A technical analysis of real-life supply chain security incidents. *Computers & Security* **159**, 104673 (Dec 2025). <https://doi.org/10.1016/j.cose.2025.104673>
16. Mladenov, M., Erd, L., Smaragdakis, G.: All that Glitters is not Gold: Uncovering Exposed Industrial Control Systems and Honeypots in the Wild . <https://doi.org/10.1109/EuroSP63326.2025.00017>
17. Morris, C.H.R., Morris, C.H.R.: *The Law of Financial Services Groups*. Oxford University Press, Oxford, New York (Oct 2019)
18. National Cyber Security Centre: Advisory: Hundreds of uk organisations at risk of compromise due to exim mail server vulnerabilities (2026), <https://www.ncsc.gov.uk/sites/default/files/documents/Advisory%20Exim%20Server%20Vulnerabilities%20v1.pdf>
19. NGINX, Inc.: Nginx (2026), <https://nginx.org/>, accessed: 2026-05-19
20. Rizvi, S.: Cyber security breaches survey 2025. GOV.UK (2025), <https://www.gov.uk/government/statistics/cyber-security-breaches-survey-2025/cyber-security-breaches-survey-2025>
21. Rosa, I.: Attack surface management (ASM): Strategic pillar of modern cybersecurity operations **1** (Dec 2025). <https://doi.org/10.31112/kriativ-tech-2023-06-97>
22. Shafee, S., Bessani, A., Ferreira, P.M.: Evaluation of LLM-based chatbots for OSINT-based Cyber Threat Awareness. *Expert Systems with Applications* **261**, 125509 (Feb 2025). <https://doi.org/10.1016/j.eswa.2024.125509>
23. Simon, J., Omar, A.: Cybersecurity investments in the supply chain: Coordination and a strategic attacker. *European Journal of Operational Research* **282**(1), 161–171 (Apr 2020). <https://doi.org/10.1016/j.ejor.2019.09.017>
24. The Apache Software Foundation: Apache http server project (2026), <https://httpd.apache.org/>, accessed: 2026-05-19